

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-HIPAA-01

HIPAA Security Rule Guide

A Practical Guide to Understanding and Implementing the HIPAA Security Rule
TSEC Compliance Insights | HIPAA Series

Document ID:	GUIDE-HIPAA-01
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

1. Introduction to the HIPAA Security Rule

The HIPAA Security Rule (45 CFR Part 164, Subpart C) requires Covered Entities and Business Associates to implement administrative, physical, and technical safeguards to protect electronic protected health information (ePHI). Enacted under HIPAA and strengthened by the HITECH Act of 2009, the Security Rule applies to all health plans, health care clearinghouses, health care providers who transmit health information electronically, and Business Associates who create, receive, maintain, or transmit ePHI on their behalf.

2. The Three Safeguard Categories

Category	Definition	Number of Standards
Administrative Safeguards	Administrative actions, policies, and procedures to manage the selection, development, implementation, and maintenance of security measures and Workforce conduct	9 standards
Physical Safeguards	Physical measures, policies, and procedures to protect electronic information systems and related buildings and equipment from environmental hazards and unauthorized intrusion	4 standards
Technical Safeguards	The technology and policy/procedures for its use that protect ePHI and control access to it	5 standards

3. Required vs. Addressable Implementation Specifications

One of the most misunderstood aspects of the HIPAA Security Rule is the distinction between 'Required' and 'Addressable' implementation specifications.

Required Specifications

Required implementation specifications must be implemented. There is no flexibility. Examples include: Risk Analysis, Assigned Security Responsibility, unique user identification, emergency access procedures, audit controls, and person or entity authentication.

Addressable Specifications

Addressable does NOT mean optional. For each addressable specification, the covered entity must assess whether it is a reasonable and appropriate safeguard in its environment. If it is reasonable and appropriate, the specification must be implemented. If it is not reasonable and appropriate, the covered entity must document why and implement an equivalent alternative measure — or document why neither the specification nor an alternative is reasonable and appropriate. This determination must be documented and retained.

4. Key Administrative Safeguards in Practice

Risk Analysis and Risk Management

The Risk Analysis (45 CFR 164.308(a)(1)(ii)(A)) is the most fundamental requirement of the Security Rule, and the one most commonly cited in OCR enforcement actions. OCR has imposed civil monetary penalties ranging from thousands to millions of dollars on organizations

that failed to conduct an adequate risk analysis or that conducted one but failed to act on its findings. An adequate risk analysis must be accurate, thorough, and organization-wide — it cannot cover only a subset of systems that handle ePHI.

Security Incident Procedures

Required by 45 CFR 164.308(a)(6), this standard requires policies and procedures to address security incidents. Critically, this includes the obligation to identify and respond to suspected or known security incidents, mitigate harmful effects, and document incidents and their outcomes. Security incident response is the bridge between the Security Rule and the Breach Notification Rule — a security incident involving ePHI must be evaluated to determine whether it constitutes a reportable breach.

Workforce Training

45 CFR 164.308(a)(5) requires periodic security awareness and training for all Workforce members, covering security reminders, protection from malicious software, log-in monitoring, and password management. Human error remains one of the leading causes of healthcare data breaches — inadequate training is not just a compliance gap but a real-world risk.

5. The Breach Notification Rule

While technically a separate rule under 45 CFR Part 164, Subpart D, the Breach Notification Rule is closely linked to the Security Rule. A breach occurs when there is an impermissible use or disclosure of unsecured PHI that compromises the security or privacy of the PHI. The key notification obligations are:

To Whom	When	How
Affected Individuals	Within 60 days of discovery	Written notice by first-class mail (or email if individual agreed); content requirements specified at 45 CFR 164.404(c)
HHS Secretary	Breaches affecting 500+ individuals: contemporaneous with individual notice (within 60 days). Breaches affecting <500: within 60 days of end of calendar year	HHS OCR online breach reporting portal
Prominent Media Outlets	Breaches affecting 500+ residents of a state or jurisdiction: within 60 days of discovery	Prominent media outlets serving the affected area

6. Common HIPAA Security Rule Enforcement Actions

OCR investigates breaches reported to HHS and complaints filed by individuals. Common findings in enforcement actions include:

- Failure to conduct an enterprise-wide risk analysis (the most common finding in OCR settlements)
- Failure to implement the policies and procedures identified as necessary by the risk analysis
- Failure to obtain Business Associate Agreements with vendors who have access to ePHI

- Impermissible disclosure of PHI through unauthorized access, theft of devices, or misconfigured systems
- Failure to implement technical safeguards, particularly encryption on portable devices (laptops, USB drives)

7. HIPAA Security Rule and Modern Healthcare Technology

The Security Rule was written in 2003 and has not been updated to specifically address cloud computing, AI-assisted diagnosis tools, wearables, or remote patient monitoring. However, OCR has issued guidance confirming that the Security Rule's flexible, scalable approach applies to all forms of ePHI regardless of the technology used. Organizations using cloud services must ensure their agreements with cloud providers meet Business Associate Agreement requirements, even if the provider's standard terms don't offer a BAA.

8. Key Takeaways

- The Security Rule requires all Covered Entities and Business Associates to implement administrative, physical, and technical safeguards for ePHI
- 'Addressable' does not mean optional — it means the organization must assess whether the specification is reasonable and appropriate and implement it or document why not
- The Risk Analysis is the most critical requirement — inadequate risk analysis is the most common finding in OCR enforcement actions
- The Breach Notification Rule requires notification to individuals, HHS, and in some cases the media when a breach of unsecured PHI occurs
- Business Associate Agreements are required with all vendors who create, receive, maintain, or transmit ePHI — failure to obtain them is a reportable compliance deficiency

9. OCR Enforcement Trends and Lessons Learned

HHS OCR's enforcement record provides a valuable map of where real-world HIPAA Security Rule failures most commonly occur. A review of settlements and civil monetary penalty cases reveals consistent patterns:

Enforcement Theme	What Went Wrong	Lesson for Compliance Programs
Inadequate or absent Risk Analysis	Organization never conducted a comprehensive risk analysis, or conducted a limited assessment that did not cover all ePHI systems	Conduct an enterprise-wide risk analysis covering every system and location where ePHI resides; update it at least annually and upon significant changes
Failure to implement identified safeguards	Risk analysis was conducted but findings were not acted upon; risks remained open for years	Tie risk analysis outputs directly to a Risk Management plan with owners, timelines, and executive accountability
Failure to obtain Business Associate Agreements	PHI was shared with vendors, cloud providers, or contractors without a BAA in place	Audit all vendors with access to ePHI; execute BAAs before sharing any ePHI; include cloud providers and IT support firms
Unencrypted portable devices	Laptops, USB drives, or backup tapes containing unencrypted ePHI were lost or stolen	Implement full-disk encryption on all portable devices; verify compliance through MDM; assess whether unencrypted portable storage is necessary

Impermissible disclosure through misconfiguration	ePHI accessible via the internet due to misconfigured server, database, or cloud storage bucket	Include cloud configuration in the risk assessment; implement cloud security posture management; conduct regular configuration audits
---	---	---

10. HIPAA in the Cloud: Key Considerations

The majority of healthcare organizations now store or process ePHI in cloud environments. Key HIPAA considerations for cloud deployments:

- Business Associate Agreements with cloud providers: IaaS providers (including major cloud providers) that store ePHI on your behalf are Business Associates and must sign a BAA. Most major providers offer BAAs — ensure yours is executed before uploading any ePHI.
- Shared responsibility model: cloud providers are responsible for the security of the infrastructure; you are responsible for security within your environment. This means your risk analysis must address your responsibilities — encryption key management, access controls, configuration management — not just the provider's.
- Data residency: if your BAA or applicable state law requires ePHI to remain within the United States, confirm that your cloud provider's region configuration ensures data doesn't replicate to international regions.
- Audit logging: ensure that cloud audit logs (e.g., AWS CloudTrail, Azure Activity Log) are enabled and retained for a sufficient period to support security incident investigation.
- Sub-BAAs: your cloud provider may use subprocessors who also have access to your data. Review the provider's subprocessor list and confirm that the BAA chains down to subprocessors.

11. HIPAA Security Rule Quick Reference

If you need to address...	Look at this standard
How we manage security risks across our organization	164.308(a)(1) Security Management Process — Risk Analysis and Risk Management
Who is responsible for our security program	164.308(a)(2) Assigned Security Responsibility
How we control who has access to ePHI	164.308(a)(3)-(4) Workforce Security and Information Access Management; 164.312(a) Access Control
How we train our staff	164.308(a)(5) Security Awareness and Training
How we respond to security incidents	164.308(a)(6) Security Incident Procedures
How we keep systems running in an emergency	164.308(a)(7) Contingency Plan
How we manage our vendors/Business Associates	164.308(b) Business Associate Contracts; 164.314 Organizational Requirements
How we protect physical access to systems	164.310 Physical Safeguards
How we protect against unauthorized system access	164.312(a) Access Control; 164.312(d) Authentication
How we ensure data hasn't been tampered with	164.312(c) Integrity
How we protect data in transit	164.312(e) Transmission Security

How long we keep our documentation	164.316 Policies, Procedures, and Documentation — 6-year retention
------------------------------------	--